

- Threat Hunt Generation Report: FortiBleed campaign used custom FortiGate sniffer to steal credentials
 - Executive Summary
 - Threat Actors
 - Campaigns
 - FortiBleed
 - Malware
 - FortigateSniffer (Backdoor)
 - Indicators of Compromise
 - Observed Behaviors
 - MITRE ATT&CK Mapping
 - PEAK Hunt Hypotheses
 - Hunt 1
 - Prepare
 - Execute
 - Gather Data
 - Analysis Steps
 - Supporting Evidence
 - Act
 - Findings to Preserve
 - Future Hunt Recommendations
 - Hunt 2
 - Prepare
 - Execute
 - Gather Data
 - Analysis Steps
 - Supporting Evidence
 - Act
 - Findings to Preserve
 - Future Hunt Recommendations

Threat Hunt Generation Report: FortiBleed campaign used custom FortiGate sniffer to steal credentials

Field	Value
Source	BleepingComputer
Published	2026-06-22 20:01 UTC
URL	https://www.bleepingcomputer.com/news/security/fortibleed-campaign-used-custom-fortigate-sniffer-to-steal-credentials/
Classification	Security Incident
Report Generated	2026-06-23 13:34 UTC
Model	cth-qwen:latest
LLM Processing Time	654.49s

Executive Summary

The FortiBleed campaign targeted FortiGate devices using a custom sniffer tool called FortigateSniffer to steal credentials. Threat actors exploited compromised FortiGate firewalls by leveraging the diagnose sniffer packet command to capture authentication traffic, extracting credentials from protocols like RADIUS, LDAP, and Kerberos. The stolen data was processed using tools like SNIFTRAN and Hashcat for password cracking.

Threat Actors

None identified.

Campaigns

FortiBleed

- Aliases: —

- **Description:** Large-scale campaign targeting FortiGate devices to harvest authentication secrets via custom sniffers. The operation compromised over 430,000 FortiGate firewalls globally.
- **Evidence:** SOCRadar's report details the campaign's activity since February 2026, including credential harvesting and exploitation of FortiOS's diagnose sniffer packet functionality.

Malware

FortigateSniffer (Backdoor)

- **Aliases:** —
- **Description:** Golang-based tool that abused FortiOS's diagnose sniffer packet command to capture authentication traffic, extracting credentials from protocols like RADIUS, NTLM, Kerberos, and LDAP.

Indicators of Compromise

None extracted.

Observed Behaviors

1. SSH used to deploy FortigateSniffer on compromised FortiGate devices

- **Evidence:** The tool reportedly connects to FortiGate devices over SSH and launches the FortiOS diagnose sniffer packet command.
- **Artifacts:** SSH, diagnose sniffer packet
- **Context:** Deployed after initial access via credential stuffing and brute-force attacks.

2. Diagnose sniffer packet command executed to capture network traffic

- **Evidence:** The command was configured to monitor traffic for authentication protocols like Kerberos, LDAP, SMB, RADIUS, and others.
- **Artifacts:** diagnose sniffer packet, Kerberos, LDAP

- **Context:** Used to intercept authentication traffic passing through compromised FortiGate devices.

3. SNIFTRAN component used to reconstruct captured traffic into PCAP files

- **Evidence:** The packet data collected from FortiGate devices was processed through a component named 'SNIFTRAN' to reconstruct traffic into PCAP files.
- **Artifacts:** SNIFTRAN, PCAP
- **Context:** Part of the credential harvesting process.

4. Python-based PCAP Deep Analysis Toolkit used to extract cleartext credentials

- **Evidence:** The toolkit parsed captured traffic to extract cleartext credentials, password hashes, Kerberos tickets, and other authentication artifacts.
- **Artifacts:** Python-based PCAP Deep Analysis Toolkit, cleartext credentials, password hashes
- **Context:** Used after data collection to process and extract sensitive information.

5. Hashcat used to crack NTLM and Kerberos hashes

- **Evidence:** The toolkit generated Hashcat-ready files containing NTLM and Kerberos hashes, which were cracked using GPU-based Hashcat instances.
- **Artifacts:** Hashcat, NTLM hashes, Kerberos hashes
- **Context:** Password cracking conducted on a distributed GPU cluster.

6. GPU-based password cracking performed on enterprise-class GPUs

- **Evidence:** Threat actors allegedly used 36 enterprise-class GPUs rented from a GenAI company to crack hashed credentials via Hashcat.
- **Artifacts:** Hashcat, GPU cluster, enterprise-class GPUs
- **Context:** Cracking operation hosted on a GenAI company's GPU compute resources.

MITRE ATT&CK Mapping

Tactic	Technique ID	Technique Name	Observed Behavior
Credential Access	T1040	Network Sniffing	SSH used to deploy FortigateSniffer on compromised FortiGate devices
Credential Access	T1040	Network Sniffing	Diagnose sniffer packet command executed to capture network traffic
Discovery	T1040	Network Sniffing	SNIFTRAN component used to reconstruct captured traffic into PCAP file
Credential Access	T1003	OS Credential Dumping	Python-based PCAP Deep Analysis Toolkit used to extract cleartext cred
Credential Access	T1110.002	Brute Force: Password Cracking	Hashcat used to crack NTLM and Kerberos hashes
Credential Access	T1110.002	Brute Force: Password Cracking	GPU-based password cracking performed on enterprise-class GPUs

PEAK Hunt Hypotheses

Hunt 1

Prepare

Hypothesis: Adversaries may be using SSH to deploy a packet capture tool on FortiGate devices to intercept authentication traffic.

Behavior Basis: SSH was used to deploy FortigateSniffer, which executes the diagnose sniffer packet command to monitor traffic for authentication protocols.

Objective: Identify SSH sessions and process executions associated with deploying the sniffer command on FortiGate devices.

Required Data Sources:

- SSH logs
- Process creation events

Execute

Gather Data

- Collect SSH session logs showing connections to FortiGate devices
- Capture process creation events for 'diagnose sniffer packet'

Analysis Steps

- Correlate SSH login events with process creation of the sniffer command
- Check for execution of the command with protocols like Kerberos/LDAP/SMB

Supporting Evidence

- SSH logs matching FortiGate IP addresses
- Process creation events for 'diagnose sniffer packet' with protocol parameters

Act

Documentation Requirements: Record SSH session timestamps, FortiGate device identifiers, and command-line parameters used with the sniffer tool.

Findings to Preserve

- SSH connection patterns to FortiGate devices
- Command-line arguments for the snifferpacket command

Future Hunt Recommendations

- Monitor for SSH connections to network devices with unusual command executions

- Track process creation events for diagnostic tools
-

Hunt 2

Prepare

Hypothesis: Adversaries may be reconstructing captured network traffic into PCAP files to analyze cleartext credentials.

Behavior Basis: The SNIFTRAN component was used to process packet data into PCAP files as part of credential harvesting.

Objective: Identify instances where SNIFTRAN is used to generate PCAP files from captured traffic.

Required Data Sources:

- File creation/modification logs
- Process execution logs

Execute

Gather Data

- Collect file creation events for PCAP files
- Capture process executions involving 'SNIFTRAN'

Analysis Steps

- Check for file artifacts matching PCAP format generated by SNIFTRAN
- Correlate file creation with network traffic capture events

Supporting Evidence

- PCAP files created with SNIFTRAN
- Process execution logs showing SNIFTRAN processing packet data

Act

Documentation Requirements: Document file hashes, timestamps, and process execution contexts for PCAP files.

Findings to Preserve

- PCAP file generation patterns
- SNIFTRAN process execution timelines

Future Hunt Recommendations

- Monitor for file creation of PCAP files without clear legitimate sources
- Track process executions of unknown components handling network data

Generated by Threat Hunt Generation Pipeline | 2026-06-23 13:34 UTC